

Incident Case Report 002:

Masqueraded WINWORD.exe

Dropping and Cleaning an Implant

Case ID: INC-2026-002 **Analyst:** Detection Engineering **Date opened:** 2026-04-04 **Classification:** TRUE POSITIVE **Severity:** High

Executive Summary

Sysmon Process Create telemetry shows a binary named WINWORD.exe running from C:\Users\IEUser\AppData\Roaming\ — not from the legitimate Microsoft Office installation directory — that spawns cmd.exe with a two-part command designed to (a) delay execution via a local ping and (b) delete a hidden DLL that had been dropped into the same user directory. The pattern is consistent with a macro-based initial-access loader that stages, executes, and then removes its payload from disk.

Timeline of Events (reconstructed from raw Sysmon evidence)

Time (UTC)	Source	Event	ATT&CK
2019-04-27 15:57:25.868	Sysmon EID 11	FileCreate: Explorer.EXE creates C:\Users\IEUser\Downloads\Fish_update.exe	T1204.002
2019-04-27 15:57:53.368	Sysmon EID 1	explorer.exe spawns C:\Users\IEUser\Downloads\Fish_update.exe	T1204.002
2019-04-27 15:57:53.837	Sysmon EID 1	Fish_update.exe spawns C:\Users\IEUser\AppData\Roaming\NvSmart.exe	T1036.005
2019-04-27 15:57:53.931	Sysmon EID 1	NvSmart.exe spawns cmd.exe with cmd.exe / A	T1059.003

Time (UTC)	Source	Event	ATT&CK
(later in corpus)	Sysmon EID 1	C: \Users\IEUser\AppData\Roaming\WINWORD.exe spawns C:\Windows\SysWOW64\cmd.exe with command: cmd /c ping 127.0.0.1&&del del /F /Q /A:H "C:\Users\IEUser\AppData\Roaming\wwlib.dll"	T1204.002, T1059.003, T1070.004
(later in corpus)	Sysmon EID 1	Same WINWORD.exe spawns explorer.exe and rundll32.exe	T1218.011

Root Cause Analysis

Initial vector

The chain begins at 15:57:25 when explorer.exe (the user's shell) creates a file Flash_update.exe in the user's Downloads directory — consistent with the user opening an email attachment or clicking a link that downloaded an executable disguised as a Flash installer.

Execution

Flash_update.exe runs from the user's Downloads folder and immediately drops NvSmart.exe into %APPDATA%\Roaming\ — a **user-writable directory** that attackers prefer because it requires no elevation to write to and blends in with normal application data. NvSmart.exe in turn spawns cmd.exe /A (the /A flag sets ANSI code page for the child process, typical of older malware).

Persistence

The masqueraded WINWORD.exe running from %APPDATA%\Roaming\ is a **masquerading payload**, not the real Microsoft Word binary. The real Word lives in C:\Program Files\Microsoft Office\.... Legitimate Office applications do not execute from user directories.

Defense Evasion

The child cmd.exe command line contains a two-stage chain:

```
cmd /c ping 127.0.0.1 && del del /F /Q /A:H "C:\Users\IEUser\AppData\Roaming\wwlib.dll"
```

- ping 127.0.0.1 acts as a **sleep replacement** (waits ~4 seconds while sending 4 ICMP packets to loopback) — used to evade sandbox timeouts and simple heuristic detections.
- del del is a **typo in the original malware**, but the intent is clear: delete the file wwlib.dll.
- del /F /Q /A:H = force delete, quiet mode, target files with the **Hidden** attribute. Attackers set the hidden attribute on dropped payloads so casual dir listings don't show them.

Evidence

Primary event (masqueraded process chain)

```
{  
  "parent": "C:\\Users\\IEUser\\AppData\\Roaming\\WINWORD.exe",  
  "child": "C:\\Windows\\SysWOW64\\cmd.exe",  
  "cmdline": "cmd /c ping 127.0.0.1&&del del /F /Q /A:H \"C:\\Users\\IEUser\\AppData\\Roaming\\wwlib.dll\""  
}
```

Supporting events (same binary, additional children)

```
{  
  "parent": "C:\\Users\\IEUser\\AppData\\Roaming\\WINWORD.exe",  
  "child": "C:\\Windows\\SysWOW64\\explorer.exe",  
  "cmdline": "\"C:\\Windows\\System32\\explorer.exe\""  
}  
  
{  
  "parent": "C:\\Users\\IEUser\\AppData\\Roaming\\WINWORD.exe",  
  "child": "C:\\Windows\\SysWOW64\\rundll32.exe",  
  "cmdline": "\"C:\\Windows\\System32\\rundll32.exe\""  
}
```

Detection rule that fired

- win_office_masquerade_appdata.yml (ID 10000001-0001-0001-0001-000000000001) — matches the masqueraded WINWORD parent.

- `win_office_spawns_powershell.yml` (ID `cccccccc-3333-3333-3333-333333333333`) — would fire if the child were PowerShell. In this case child is `cmd.exe`, so add a variant rule to cover `cmd` too.

Impact Assessment

Asset	Impact
Host	User-level compromise (no elevation observed)
User account	Any credentials cached in the user's browser / password manager are at risk
Persistence	Implant <code>NvSmart.exe</code> in <code>%APPDATA%</code> ; masqueraded <code>WINWORD.exe</code> may re-execute
Data exfil	Not observed in the sampled events but plausible given the loader pattern

Closure Classification

TRUE POSITIVE, justified by: 1. A binary named `WINWORD.exe` executing from `%APPDATA%\Roaming\` — no legitimate business justification. 2. A child `cmd.exe` with a two-stage anti-sandbox + delete-hidden-file command line. 3. A second-stage binary `NvSmart.exe` dropped into the same user directory by an unrelated downloader.

Detection Gaps Revealed

1. **The `cmd.exe` child was not caught by any current rule.** Only the parent (Office masquerade) was caught. The child command line — with `ping 127.0.0.1 && del /A:H` — should be its own detection.
2. **`NvSmart.exe` and `Flash_update.exe` execution** from user directories was not alerted.
3. **No file-create alert** for a `.exe` appearing in `%APPDATA%\Roaming\`.

Recommended Response

See `playbooks/masqueraded_office_dropper.md` (to be authored).

Immediate actions:

1. Isolate the host from the network.
2. Preserve memory for forensics before cleanup.
3. Hunt fleet-wide for `NvSmart.exe` and `Flash_update.exe` hashes.
4. Search for any process executing from `%APPDATA%\Roaming\*.exe`.
5. Reset credentials for the impacted user.

ATT&CK Mapping

- T1204.002 — User Execution: Malicious File
- T1036.005 — Masquerading: Match Legitimate Name or Location
- T1059.003 — Command and Scripting Interpreter: Windows Command Shell
- T1070.004 — Indicator Removal: File Deletion
- T1564.001 — Hide Artifacts: Hidden Files and Directories
- T1218.011 — System Binary Proxy Execution: Rundll32